南開大學

信息安全综合实验课程实验报告

实验一：私有 CA 证书签发的简单实现

学　　院　密码与网络空间安全学院

专　　业　信息安全、法学双学位班

学　　号　2313815

姓　　名　段俊宇

班　　级　信息安全、法学双学位班

一、实验目的

1、 熟悉 Openssl 工具的使用。

2、 搭建私有 CA 并生成根证书。

3、 完成证书签发、吊销流程的简单实现。

二、实验原理

1、 PKI 的基本组成

a) 公钥证书（PKC， Public Key Certificate）

PKI 的基本部件，由可信实体签名的电子记录，记录将公钥和密钥（公私钥对）所有者的身份捆绑在一起。

b) 证书作废列表（CRL，Certificate Revocation List）

证书作废列表通常由同一个可信发证实体签名。当公钥的所有者丢失私钥，或者改换名称时，需要将原有证书作废并更新证书作废列表。

c) 证书存档（Repository）

是存放公钥证书和作废证书列表的电子站点。

d) 认证机构（CA，Certificate Authority）

一个可信实体，发放和作废公钥证书，并对作废证书列表签名。

e) 注册机构（RA，Registration Authority）

一个可选 PKI 实体，与 CA 分开，不对数字证书或证书作废列表签名，而是负责记录和验证部分或所有有关信息（特别是主体的身份）的证书管理机构。

f) 署名用户（Subscriber）

作为主体署名证书并依据策略使用证书和密钥的实体。

g) 依赖方（Relying Party）

一个接收包括证书和签名信息的人或机构，利用证书提供的公钥验证其有效性，与持证人建立保密通信。依赖方与署名用户统称最终用户（End-User）。

h) 策略管理机构（PMA，Policy Management Authority）

监督证书策略的产生和更新，管理 PKI 证书策略。

2、 PKI 的主要运行流程

①署名用户向 RA 提出数字证书申请

②RA 对署名用户进行身份确认

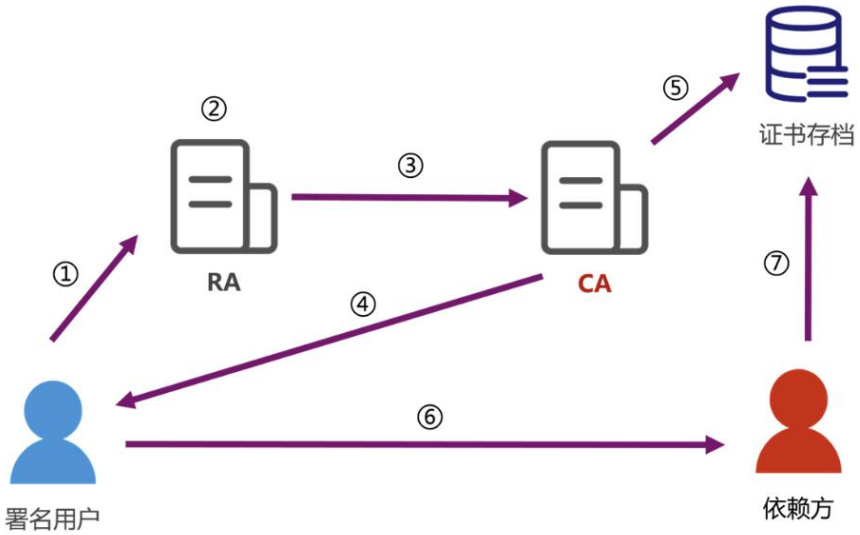
③RA 向 CA 提出发行申请

④CA 对署名用户发行证书

⑤CA 在证书存档里公开发行的证书及作废列表

⑥署名用户和依赖方通信

⑦依赖方通过证书存档来检验证书的有效性，然后利用公钥来验证电子签名、进行数据加密等



3、 CA 的职责

- 接收证书申请请求
- 用自己的私钥签发证书
- 接收证书查询请求
- 接收证书作废请求
- 提供证书作废列表

三、实验环境

Ubuntu20.04 操作系统 + OpenSSL 1.1.1f

四、实验过程

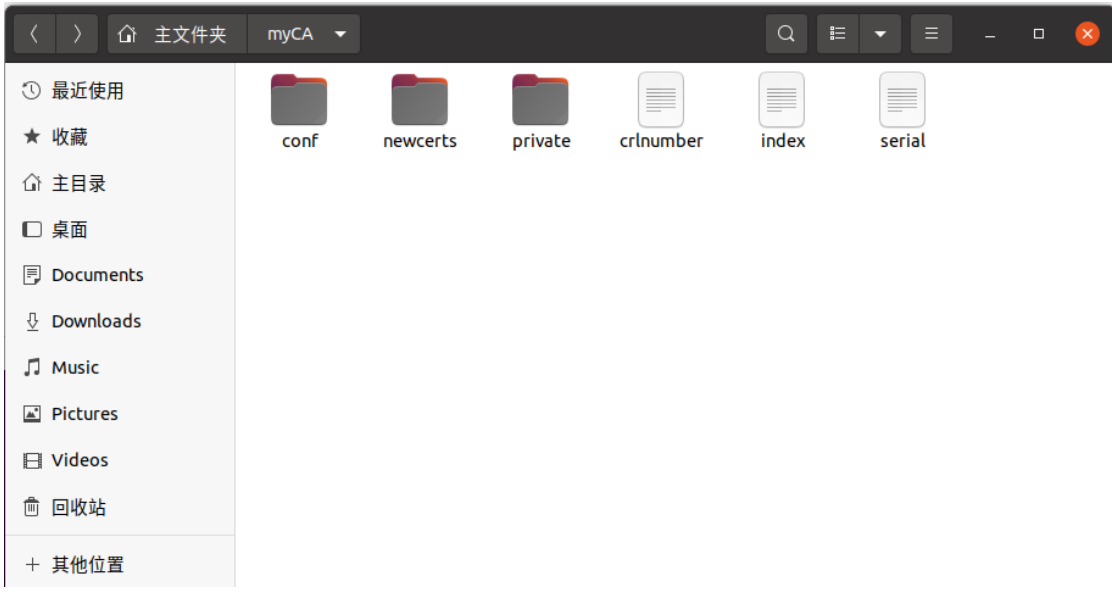
1.搭建私有 CA

（1） 创建私有 CA 所需要的文件目录，保存 CA 的相关信息

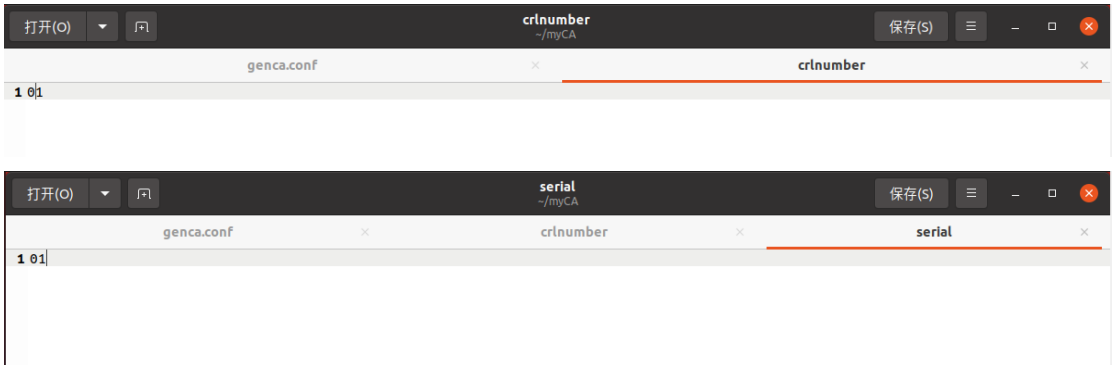
```
1. mkdir myCA //创建 CA 根文件夹
```

```
2. cd myCA //进入 CA 根文件夹
3. mkdir newcerts private conf //创建三个文件夹，用来存放新发放证书、私钥和配置文件
4. chmod g-rwx,o-rwx private //设置 private 文件夹的操作权限
5. touch index serial crlnumber //创建证书信息数据库、证书序号文件、crl 序号文件
6. echo 01 > serial //初始化证书的序号
7. echo 01 > crlnumber //初始化吊销证书序号
```

如下图所示是创建的文件



打开 crlnumber 和 serial 两个文件后发现内容均初始化为 01



（2） 创建生成 CA 自签名证书的配置文件

在 conf 文件夹中创建 genca.conf，内容如下所示

```
1. [req]
2. default_keyfile = /home/tom/myCA/private/cakey.pem
3. default_md = md5
4. prompt = no
5. distinguished_name = ca_distinguished_name
6. x509_extensions = ca_extensions
7.
8. [ca_distinguished_name]
9. organizationName = DJYorg
```

```
organizationalUnitName = DJYunit
commonName = DJY
emailAddress = 672357940@qq.com

[ca_extensions]
basicConstraints = CA:true
```

（3） 生成私有 CA 的私钥和自签名证书（根证书）

通过 openssl req -x509 -newkey rsa:2048 -out cacert.pem -outform PEM -days 2190 -config /home/tom/myCA/private/cakey.pem 命令配置，结果如下所示：

```
root@ubuntu:/home/tom/myCA# openssl req -x509 -newkey rsa:2048 -out cacert.pem -
outform PEM -days 2190 -config /home/tom/myCA/conf/genca.conf
Generating a RSA private key
.........+++++
...............................+++++
writing new private key to '/home/tom/myCA/private/cakey.pem'
Enter PEM pass phrase:
Verifying - Enter PEM pass phrase:
-----
```

（4） 查看自签名证书

通过 openssl x509 -in cacert.pem -text -noout 命令查看 cakey.pem 内容如下，说明根证书配置成功。

```
root@ubuntu:/home/tom/myCA# openssl x509 -in cacert.pem -text -noout
Certificate:
    Data:
        Version: 3 (0x2)
        Serial Number:
            55:fb:ef:be:6f:13:33:9f:eb:f7:f4:93:e2:9c:18:89:46:34:85:75
        Signature Algorithm: md5WithRSAEncryption
        Issuer: O = DJYorg, OU = DJYunit, CN = DJY, emailAddress = 672357940@qq.com
        Validity
            Not Before: Mar  4 07:20:20 2026 GMT
            Not After : Mar  2 07:20:20 2032 GMT
        Subject: O = DJYorg, OU = DJYunit, CN = DJY, emailAddress = 672357940@qq.com
        Subject Public Key Info:
            Public Key Algorithm: rsaEncryption
                RSA Public-Key: (2048 bit)
                Modulus:
                    00:c2:a3:13:8c:4d:5b:b2:27:cf:5c:32:96:3c:e2:
                    62:8e:6e:a2:aa:f8:c3:f6:3b:4d:d4:53:1b:6d:e5:
                    de:92:34:1f:c1:95:b1:19:aa:2c:bf:d3:ec:73:12:
                    21:8e:22:81:d5:b0:8b:43:65:1b:3e:34:de:7b:3f:
                    79:62:ba:d4:cf:be:5c:b6:f9:2a:41:74:30:ea:44:
                    43:6b:b6:3a:fa:57:52:1c:f4:99:d0:26:96:23:59:
                    08:33:54:59:46:d8:16:19:31:36:be:91:27:f1:61:
                    e0:75:50:60:a3:ae:18:f0:49:85:3e:4f:d0:b4:3c:
                    dd:83:4c:5b:89:b0:99:2c:dc:17:3d:fe:bb:a3:d0:
                    cc:05:13:0f:d2:b9:91:d5:a1:8a:72:8e:89:7b:7e:
                    07:8e:4e:5a:44:e4:7c:4e:f6:de:8c:cc:5c:3a:ef:
                    ea:a2:54:59:b8:b0:75:1e:3b:79:c5:47:26:47:d2:
                    43:68:b6:55:01:5c:fd:9c:f8:22:06:d9:95:e0:45:
                    b1:b0:f0:31:97:cd:1b:d6:7f:ba:96:9c:28:02:5a:
                    78:34:9b:a2:75:6d:96:7c:d7:64:c5:79:d1:a4:98:
                    da:eb:ac:40:bc:c8:50:75:97:a5:72:82:6c:cf:f9:
                    ca:82:3a:83:c8:a8:36:53:25:89:c9:32:0f:05:e1:
                    2c:6b
                Exponent: 65537 (0x10001)
        X509v3 extensions:
            X509v3 Basic Constraints:
                CA:TRUE
    Signature Algorithm: md5WithRSAEncryption
         54:4e:00:91:c5:d8:81:b2:7a:b8:52:f2:ca:cf:6a:fe:36:f1:
         ac:85:bf:86:97:27:5d:48:c4:13:84:34:00:6f:69:45:c9:97:
         2b:53:89:94:c0:6f:74:f6:5e:9f:f6:ac:32:57:0f:9d:77:0e:
         7f:04:19:29:90:27:18:dc:1f:ab:0c:62:74:64:52:8a:05:84:
         b7:82:c2:4a:50:69:69:70:c3:7c:bf:e5:86:b6:6c:f5:e6:92:
         16:c4:48:55:3d:e6:f0:ac:85:f8:d9:fb:11:00:2c:22:8b:73:
         6f:85:4d:7f:b9:e6:1d:30:ef:ff:5f:ca:e8:73:ed:1a:29:f1:
         2e:e6:09:f1:d0:d0:92:82:aa:20:39:ac:91:63:24:1a:52:64:
         1a:78:e0:32:49:2d:eb:a6:df:18:93:dc:6f:11:50:1d:e5:bf:
         8d:8d:c0:da:78:cc:09:86:95:a2:a2:49:af:bb:0c:bb:e3:95:
         6f:b1:6b:c3:8a:8d:df:0a:f9:93:40:5a:ab:09:63:06:2c:58:
         78:b1:77:8d:a0:f1:7d:4d:fd:03:9a:7c:4b:14:63:d2:ef:db:
         3f:1a:82:f8:4b:94:e2:e9:b3:75:a1:1a:24:2d:4a:ad:d4:8a:
         4c:7f:67:1b:25:52:58:15:7a:42:df:ec:97:94:95:ef:39:87:
         d8:e2:07:5f
```

2、 私有 CA 为服务器签发证书

（1） 创建用来为其他请求签发证书的配置文件

首先进入 conf 文件夹并创建为其他请求签发证书的配置文件，内容如下所示：

```
[ca]
default_ca = myCA

[myCA]
dir = /home/tom/myCA
crl_dir = $dir/conf
database = $dir/index
new_certs_dir = $dir/newcerts

certificate = $dir/cacert.pem
serial = $dir/serial
private_key = $dir/private/cakey.pem
crlnumber = $dir/crlnumber
RANDFILE = $dir/private/.rand

default_days = 365
default_crl_days = 30
default_md = md5
unique_subject = no

policy = policy_any

[policy_any]

stateOrProvinceName = optional
localityName = optional
organizationName = optional
organizationalUnitName = optional
commonName = supplied
emailAddress = optional
```

（2） 模拟服务器，生成私钥与证书申请的请求文件

命令如下所示：

```
mkdir server //在任意路径下创建服务器文件夹 server
openssl req -newkey rsa:1024 -keyout server.key -out serverreq.pem -subj
“/O=ServerCom/OU=ServerOU/CN=server” //生成 server 的 1024 位私钥 server.key 和证书申请的请
求文件 serverre.pem
```

配置结果如下所示：

```
root@ubuntu:/home/tom/server# openssl req -newkey rsa:1024 -keyout server.key -
out serverreq.pem -subj "/O=ServerCom/OU=ServerOU/CN=server"
Generating a RSA private key
...............+++++
..........................+++++
writing new private key to 'server.key'
Enter PEM pass phrase:
Verifying - Enter PEM pass phrase:
-----
```

（3） CA 根据服务器的证书请求文件生成证书并将其返回给服务器

通过 openssl ca -in serverreq.pem -out server.crt -config /home/tom/myCA/conf/ca.conf 命令向私有 CA 提交证书请求文件 serverreq.pem，CA 生成并返回证书 server.crt。结果如下所示，说明成功签发证书。

```
root@ubuntu:/home/tom/server# openssl ca -in serverreq.pem -out server.crt -con
fig /home/tom/myCA/conf/ca.conf
Using configuration from /home/tom/myCA/conf/ca.conf
Enter pass phrase for /home/tom/myCA/private/cakey.pem:
Check that the request matches the signature
Signature ok
The Subject's Distinguished Name is as follows
organizationName      :ASN.1 12:'ServerCom'
organizationalUnitName:ASN.1 12:'ServerOU'
commonName            :ASN.1 12:'server'
Certificate is to be certified until Mar  4 07:43:00 2027 GMT (365 days)
Sign the certificate? [y/n]:y


1 out of 1 certificate requests certified, commit? [y/n]y
Write out database with 1 new entries
Data Base Updated
```

查看证书信息数据库文件 index 和 newcerts 文件夹，发现均显示了证书内容。

```
打开(O)    index [只读]  ~/myCA    保存(S)
1 V    270304074300Z    01    unknown    /O=ServerCom/OU=ServerOU/CN=server
```

```
root@ubuntu:/home/tom/myCA/newcerts# ls
01.pem
```

3、 私有 CA 为客户端签发证书

这部分与上面的步骤基本相似，只需要将 server 改成 client 即可。配置命令如下所示：

```
root@ubuntu:/home/tom/client# openssl req -newkey rsa:1024 -keyout client.key -
out clientreq.pem -subj "/O=ClientCom/OU=ClientOU/CN=client"
Generating a RSA private key
......+++++
................+++++
writing new private key to 'client.key'
Enter PEM pass phrase:
Verifying - Enter PEM pass phrase:
-----
```

提交请求的命令如下所示：

```
root@ubuntu:/home/tom/client# openssl ca -in clientreq.pem -out client.crt -con
fig /home/tom/myCA/conf/ca.conf
Using configuration from /home/tom/myCA/conf/ca.conf
Enter pass phrase for /home/tom/myCA/private/cakey.pem:
Check that the request matches the signature
Signature ok
The Subject's Distinguished Name is as follows
organizationName      :ASN.1 12:'ClientCom'
organizationalUnitName:ASN.1 12:'ClientOU'
commonName            :ASN.1 12:'client'
Certificate is to be certified until Mar  4 07:50:46 2027 GMT (365 days)
Sign the certificate? [y/n]:y


1 out of 1 certificate requests certified, commit? [y/n]y
Write out database with 1 new entries
Data Base Updated
```

最终成功签发证书，数据库内容及证书文件夹如下：

```
打开(O)    Index [只读]  ~/myCA    保存(S)
1 V    270304074300Z    01    unknown    /O=ServerCom/OU=ServerOU/CN=server
2 V    270304075046Z    02    unknown    /O=ClientCom/OU=ClientOU/CN=client
```

```
root@ubuntu:/home/tom/myCA/newcerts# ls
01.pem  02.pem
```

4、 CA 吊销用户证书

（1） 找到需要吊销的用户证书序号并使用 openssl ca 指令完成用户证书吊销

首先确定需要吊销的证书，我吊销了 server.crt 这个证书，命令为 openssl ca -revoke 01.pem -config /home/tom/myCA/conf/ca.conf。这里的 revoke 代表吊销某个证书，数据库中已吊销证书信息得到开头不再是 V，而是 R。

```
root@ubuntu:/home/tom/myCA/newcerts# openssl ca -revoke 01.pem -config /home/to
m/myCA/conf/ca.conf
Using configuration from /home/tom/myCA/conf/ca.conf
Enter pass phrase for /home/tom/myCA/private/cakey.pem:
Revoking Certificate 01.
Data Base Updated
```

数据库更新后如下所示：

```
R	270304074300Z	260304075748Z	01	unknown	/O=ServerCom/OU=ServerOU/CN=server
V	270304075046Z	02	unknown	/O=ClientCom/OU=ClientOU/CN=client
```

（2） 更新并重新生成证书吊销列表 CRL

通过 openssl ca -gencrl -out /home/tom/myCA/crl/ca.crl -config /home/tom/myCA/conf/ca.conf 命令完成证书吊销列表 CRL 的更新和重新生成。

```
root@ubuntu:/home/tom/myCA# mkdir crl
root@ubuntu:/home/tom/myCA# openssl ca -gencrl -out /home/tom/myCA/crl/ca.crl -
config /home/tom/myCA/conf/ca.conf
Using configuration from /home/tom/myCA/conf/ca.conf
Enter pass phrase for /home/tom/myCA/private/cakey.pem:
```

更新后，原先的 CRL 序号文件 crlnumber 会增加，代表吊销了一个证书，如下所示，从 01 变成了 02。

```
02
```

最终的 ca.crl 内容如下，说明成功更新了文件：


```
-----BEGIN X509 CRL-----
MIIBwTCBqgIBATANBgkqhkiG9w0BAQQFADBSMQ8wDQYDVQQKDAZESllvcmcxEDAO
BgNVBAsMB0RKWXVuaXQxDDAKBgNVBAMMA0RKWTEfMB0GCSqGSIb3DQEJARYQNjcy
MzU3OTQwQHFxLmNvbRcNMjYwMzA0MDgwNDE4WhcNMjYwNDAzMDgwNDE4WjAUMBIC
AQEXDTI2MDMwNDA3NTc0OFqgDjAMMAoGA1UdFAQDAgEBMA0GCSqGSIb3DQEBBAUA
A4IBAQBDZXanm5T9jiy6m9uT1yycJOP/25wGNqieOab09N1B5MRhtKpcLSCeoKlg
C+u1mybGilJnTND8zWll6EEdvQy1BrTmKjPnuv2yKqStg/f7CMGnTMXPjvw+S8Vr
zCruY9y0dCAag7mbp7EySSKAbIYXhmlBTicurcYhuEgq3TfPwWYNByyuG7FN4F/I
CUvHbQPhgC+0l4+290zmao8c940NT5s+PKaah3G5LfTf8W+2DAWB/yVBTGODoY2q
Td6k4jZMqmTk/qjfkkVSoyl8rzvhs2U4TRtnx9CxpuUnrtOeYeiBwzKhIwxivq8I
8NrYEjtFWyQeKzc/H8ee480Id3ya
-----END X509 CRL-----
```


思考题：CA 如何验证证书的有效性？需要考虑到哪些方面？

通过本次实验我了解到 CA 通过公钥算法验证证书的有效性，然后核对当前时间是否在证书有效期内，并通过 CRL 查询其是否被撤销，最后严格检查证书中的域名是否与当前访问的网站匹配。上述环节均验证通过时，证书才被认定为有效。

五、实验结论及心得体会

本次实验中我通过 openssl 库实现了私有 CA 证书签发过程的简单模拟，

在这一过程中我学习到了 openssl 的各种命令，并且对证书签发、吊销和验证流程有了基本认识，扩充了信息安全的基础知识。